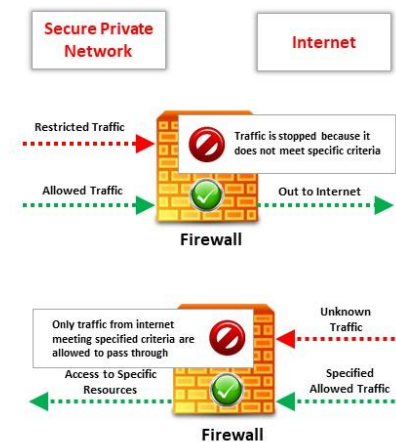




What is a Firewall?

- ❑ Firewall is a software or hardware, or a combination of both, **which is generally used to separate a protected network from an unprotected public network**
- ❑ It monitors and filters the incoming and outgoing **traffic** of the network and prevents unauthorized access to private networks



Copyright © by **IC Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

What is a Firewall?

A firewall is a software or hardware, or a combination of both, which is generally used to separate a protected network from an unprotected public network. A firewall is a secure, reliable, and trusted device placed in between private and public networks. It helps in protecting a private network from the users of a different network. It monitors and filters the incoming and outgoing traffic of the network and prevents unauthorized access to private networks. It has a set of rules for tracing the incoming and outgoing network traffic and is also responsible for allowing or denying traffic to pass through. These criteria are the rules and restrictions configured on the firewall and they may vary from one type of firewall to another. Generally, a firewall filters traffic based on the type of traffic, source or destination addresses, protocols, and ports.

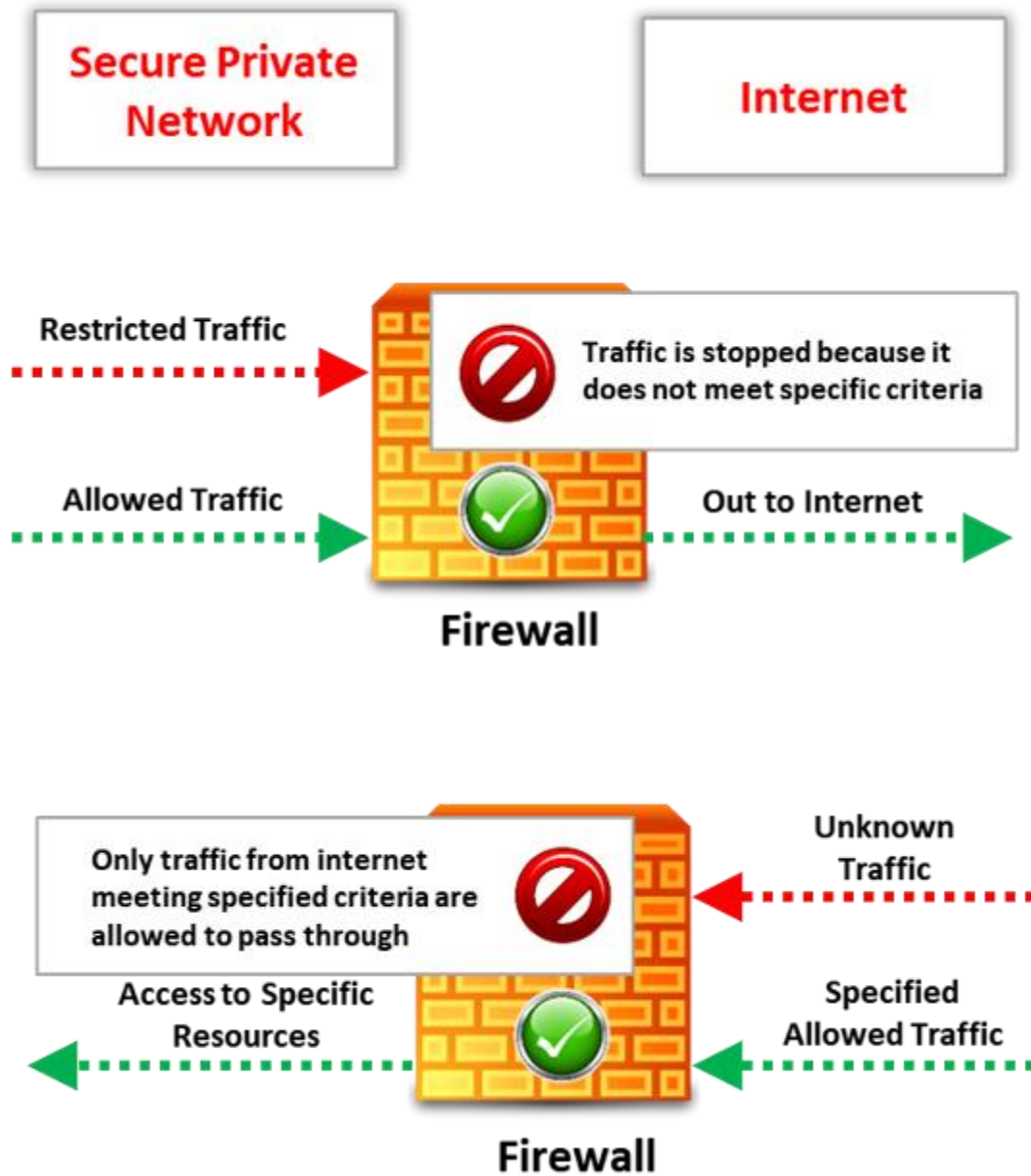


Figure 5.13: Working of a firewall

Typical use of firewalls:

- To protect the private network applications and services on the internal network from the unauthorized traffic and the public network.
- To restrict the access of the hosts on the private network and the services of the public network.

- To support a network address translation, which helps in using private IP addresses and to share a single internet connection.

Types of Firewalls: Hardware Firewalls

01 A hardware firewall is either a dedicated **stand-alone hardware device** or it comes as part of a router

02 The network traffic is filtered using the **packet filtering** technique

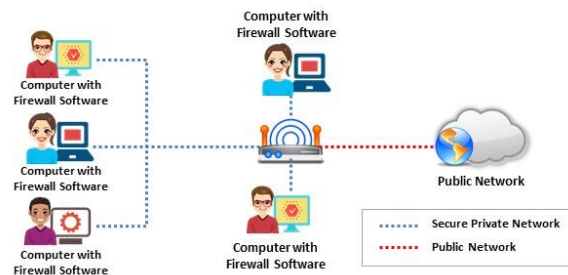
03 It is used to **filter out** the network traffic for large business networks

Copyright © by **IC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.



Types of Firewalls: Software Firewalls

- ☐ A software firewall is a **software program** installed on a computer, just like normal software
- ☐ It is generally used to **filter traffic** for individual home users
- ☐ It only filters traffic for the computer on which it is **installed**, not for the entire network



Note: It is recommended that you configure both a software and a hardware firewall for best protection

Types of Firewalls: Host-based and Network-based Firewalls

Host-based Firewalls

- ❑ The host-based firewall is used to filter inbound/outbound traffic of an **individual computer** on which it is installed
- ❑ It is a **software-based** firewall
- ❑ This firewall software comes as part of OS
- ❑ **Example:** Windows Firewall, Iptables, UFW etc.

Network-based Firewalls

- ❑ The network-based firewall is used to filter inbound/outbound traffic from **Internal LAN**
- ❑ It is a **hardware-based** firewall
- ❑ **Example:** pfSense, Smoothwall, Cisco SonicWall, Netgear, ProSafe, D-Link, etc.



Note: It is recommended to configure both a host and network-based firewall for best protection

Copyright © by **IC Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Hardware Firewall

Advantages:

- Security: A hardware firewall with its operating system (OS) is considered to reduce security risks and increase the level of security controls.
- Speed: Hardware firewalls initiate faster responses and enable more traffic.
- Minimal Interference: Since a hardware firewall is a separate network component, it enables better management and allows the firewall to shut down, move, or be reconfigured without much interference in the network.

Disadvantages:

- More expensive than a software firewall.
- Difficult to implement and configure.

▪ Software Firewalls

Advantages:

- Less expensive than hardware firewalls.

- Ideal for personal or home use.
- Easier to configure and reconfigure.

Disadvantages:

- Consumes system resources.
- Difficult to uninstall.
- Not appropriate for environments requiring faster response times.

▪ Host-based Firewalls

A host-based firewall is a software-based firewall that can filter inbound/outbound traffic of an individual computer on which it is installed and checks for any malicious activity throughout the network. It comes as part of the system's OS. For example, Microsoft Firewall that is part of Windows system, Iptables, Uncomplicated Firewall (UFW), etc. The different levels of traffic analysis of these firewalls include packet analysis at the network and transport layers of the OSI model. These firewalls check the MAC address, IP address, packet source, and destination port before allowing a packet to pass. Then, a stateful filter validates the packets. In the end, the packet is validated at the application layer.

Advantages

- Provides security for devices irrespective of change in location
- Provides internal security and avoids internal attacks by allowing only authorized users
- Setup requires basic hardware/software installation
- Useful for individuals and small businesses with fewer devices as they provide customized protection
- Provide flexibility by allowing applications and virtual machines (VMs) to take their host-based firewalls along with them when they are moved between cloud environments
- Allows configuring a single device for an individual's requirements using custom firewall rules

Disadvantages

- Not suitable for larger networks

- Provide less security because if an attacker can access a host, they can turn off the firewall or install malicious code undetected by the organization
- Must be replaced if bandwidth exceeds firewall throughput or, otherwise, more effort are needed to scale up every device if the number of hosts increase
- Costly, as they require individual installation and maintenance on every server for big organizations
- Dedicated IT staff is needed for maintaining each device

- **Network-based Firewalls**

A network-based firewall is a hardware-based firewall that can be used to filter inbound/outbound traffic on internal LAN. For example, pfSense, Smoothwall, CISCO SonicWall, Netgear, ProSafe, D-Link, etc. Such a firewall functions on the network level and filters data that traverses through the network, forming a network perimeter as the first line of defense. It functions by routing traffic to proxy servers, which manage data transmission in the network.

Advantages

- Network-based firewalls do not require individual installation and maintenance on every server.
- As any malicious traffic would exist at the network barrier, they can provide greater security than what host-based firewalls can provide a host.
- They allow scalability when a client's bandwidth demands increase.
- They offer high availability (uptime) and their security can be extended beyond a single service provider network.
- They require a limited workforce that may be needed to manage one or two sets of network firewalls.
- They are appropriate for SMEs or organizations with large networks.

Disadvantages

- They do not consider applications and vulnerabilities on a system/VM.
- They do not provide protection for host-to-host communication in the same VLAN.
- Their setup requires highly skilled resources.
- Their cost is lower in the case of big organizations.

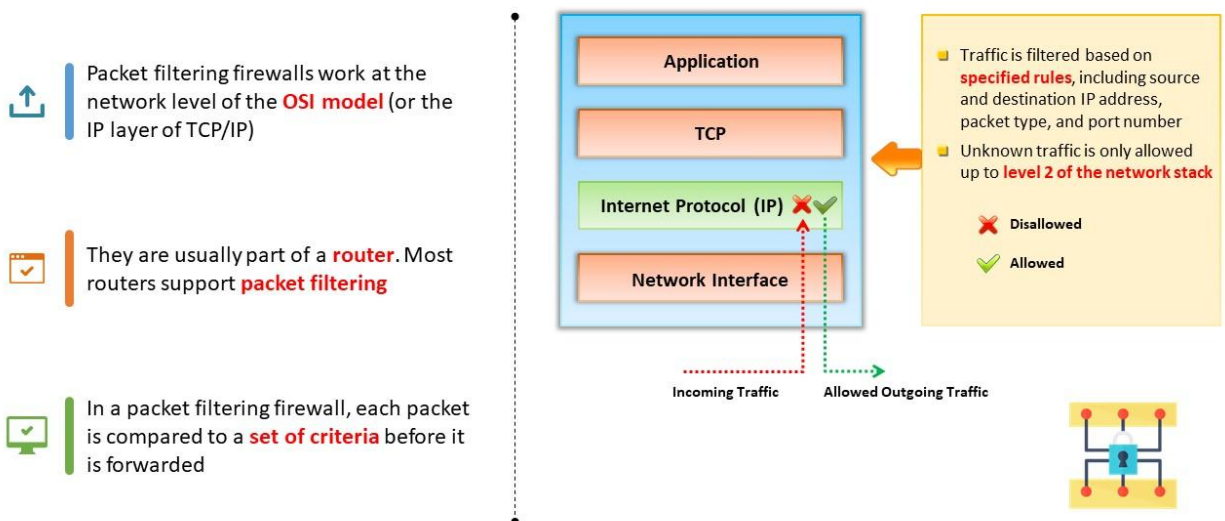
- Incorrect maintenance of network firewalls that function as proxy servers may decrease network performance.

Note: It is recommended to configure both a host and network-based firewall for best protection

In the real environment, a combination of host-based and network-based firewalls provides greater security. For example, if an attacker were able to breach the network-level security, it would still be difficult to breach each host-based firewall. This combination is suitable for big organizations with complex networks, which have higher threat levels to their sensitive data and need to meet the strong compliance standards.

Firewall Technologies

Packet Filtering Firewall



Copyright © by **TC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Packet Filtering Firewall

Packet filtering is the most basic feature of all modern firewalls. Packet filtering firewalls work at the network level of the OSI model (or the IP layer of TCP/IP). They are usually part of a router. Most routers support packet filtering. In a packet filtering firewall, each packet is compared to a set of criteria before it is forwarded. Depending on the packet and the criteria, the firewall can:

- Drop the packet
- Forward it or send a message to the originator

They evaluate each packet based on the packet header information, including source IP address, destination IP address, source port, destination port, protocol, etc. If the packet header information does not match the ruleset, the firewall drops the packet; or else, it is forwarded. Rules can include source and destination IP address, source and destination port number, or the protocol used. When a data packet passes through the network, a packet filter checks the packet header and compares it with the connection bypass table that keeps a log of the connections passing through the network. The advantage of packet filtering firewalls is their low cost and low impact on network performance.

Traffic is filtered based on specified rules including source and destination IP address, packet type, and port number. Unknown traffic is only allowed up to level 2 of the network stack.

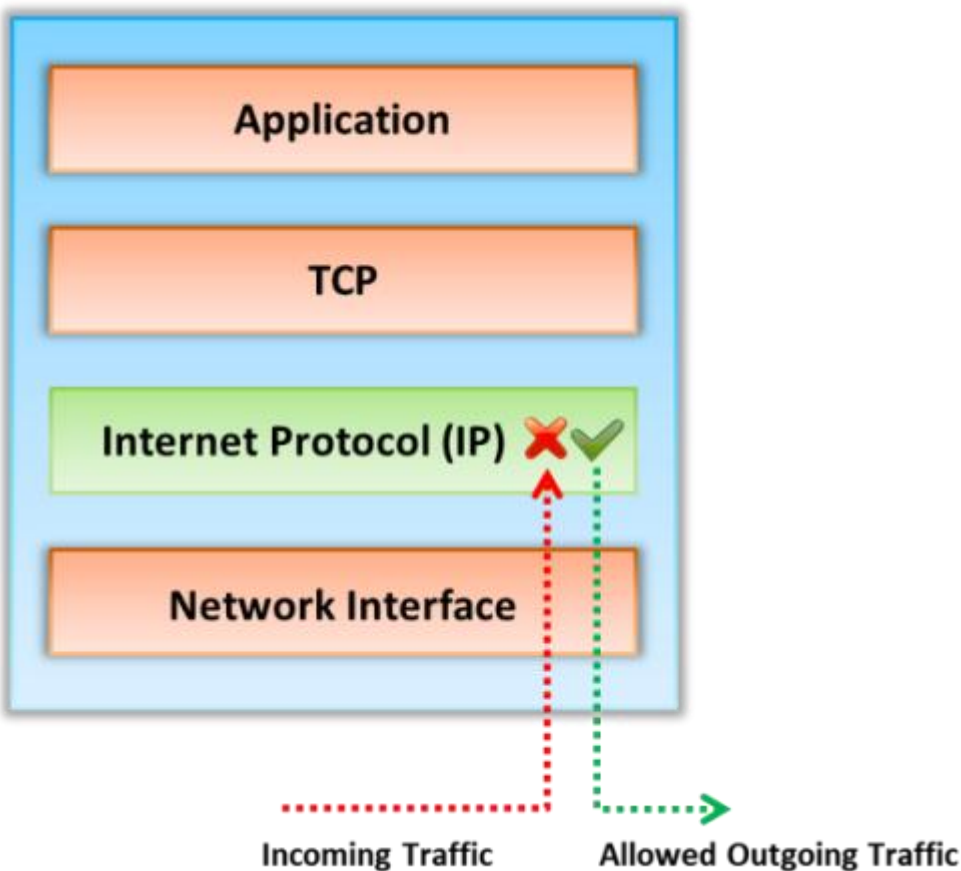
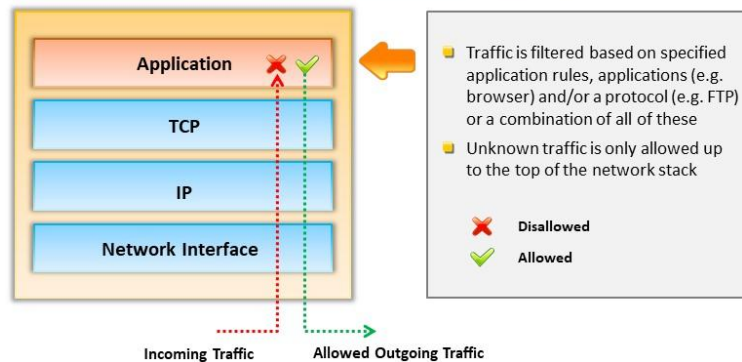


Figure 5.16: Packet Filtering Firewall

Application Level Gateways



- ❑ Application level gateways can filter packets at the application layer of the **OSI model**
- ❑ Because they examine packets at the application layer, they can filter application-specific commands such as **http:post** and **get**
- ❑ In plain terms, an application level gateways can be configured to be a web proxy which will not allow any **FTP, gopher, Telnet**, or other traffic through



Copyright © by **IC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Application Level Gateways

Application level gateways can filter packets at the application layer of the OSI model. As they examine packets at the application layer, they can filter application-specific commands such as **http:post** and **get**. In plain terms, an application level gateways can be configured to be a web proxy which will not allow any **FTP, gopher, Telnet**, or other traffic through.

An application-level gateway firewall controls input, output, and/or access across an application or service. It monitors and possibly blocks the input, output, or system service calls that do not meet the set firewall policy. Before allowing the connection, it evaluates the network packets for valid data at the application layer of the firewall.

Traffic is filtered based on specified application rules, applications (e.g. browser) and/or a protocol (e.g. FTP) or a combination of all of these. Unknown traffic is only allowed up to the top of the network stack.

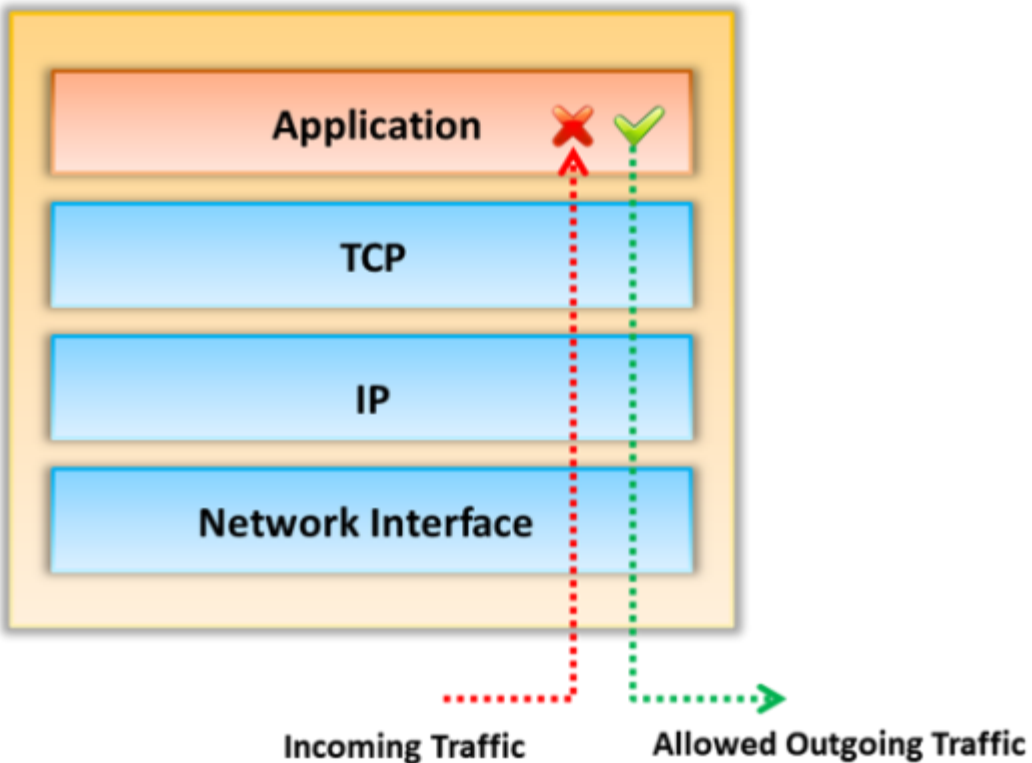
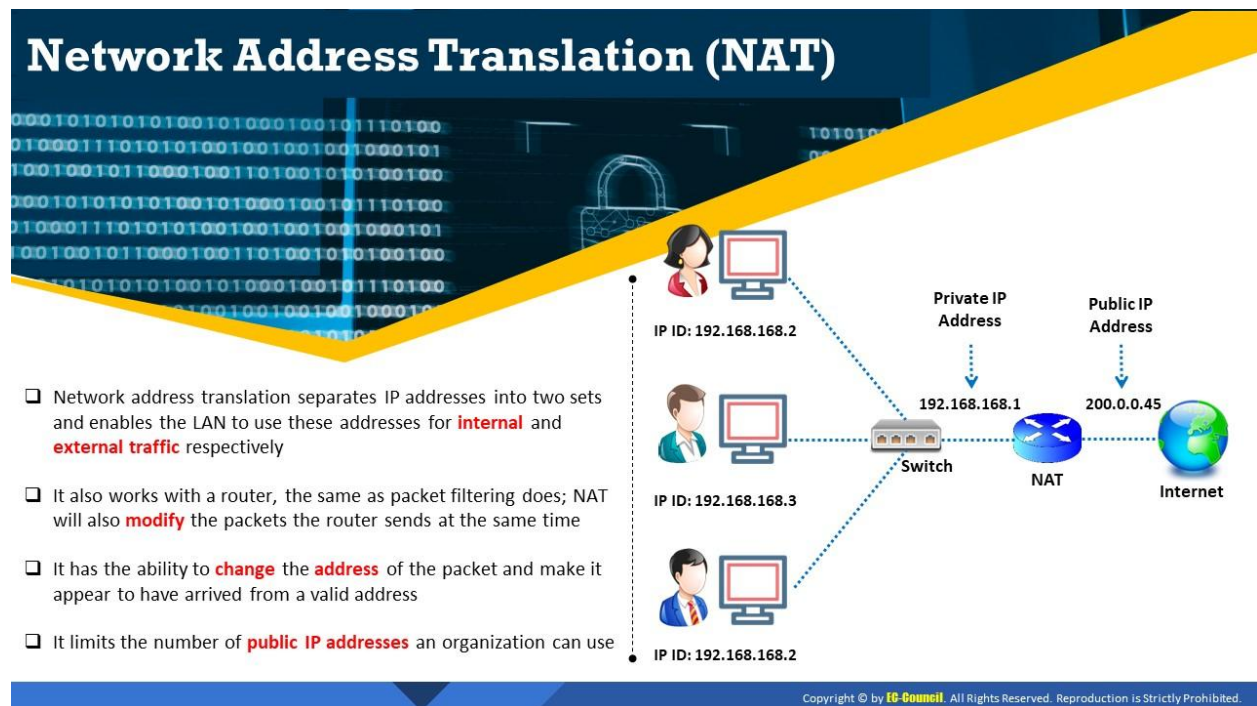


Figure 5.18: Application Level Gateway



Network Address Translation (NAT)

Network address translation separates IP addresses into two sets and enables the LAN to use these addresses for internal and external traffic, respectively. A NAT helps hide an internal network layout and forces connections to go through a choke point. It works with the help of a router, helping to send packets and modifying them. When the internal machine sends the packet to the outside machine, NAT modifies the source address of the particular packet to make it appear as if it is coming from a valid address. Similarly, when the outside machine sends the packet to the internal machine NAT modifies the destination address to turn the visible address into the correct internal address. It limits the number of public IP addresses an organization can use. It can act as a firewall filtering technique where it allows only those connections which originate on the inside network and will block the connections which originate on the outside network. NATs can also modify the source and destination port numbers. NAT systems use different schemes for translating between internal and external addresses:

- Assigning one external host address for each internal address and always applying the same translation. This slows down connections and does not provide any savings in address space.
- Dynamically allocating an external host address without modifying the port numbers at the time when the internal host initiates a connection. This restricts the number of internal hosts that can simultaneously access the Internet to the number of available external addresses.
- Creating a fixed mapping from internal addresses to externally visible addresses and using port mapping so that multiple internal machines use the same external addresses.
- Dynamically allocating a pair of external host address and port each time an internal host initiates a connection. This makes the most efficient possible use of the external host addresses.

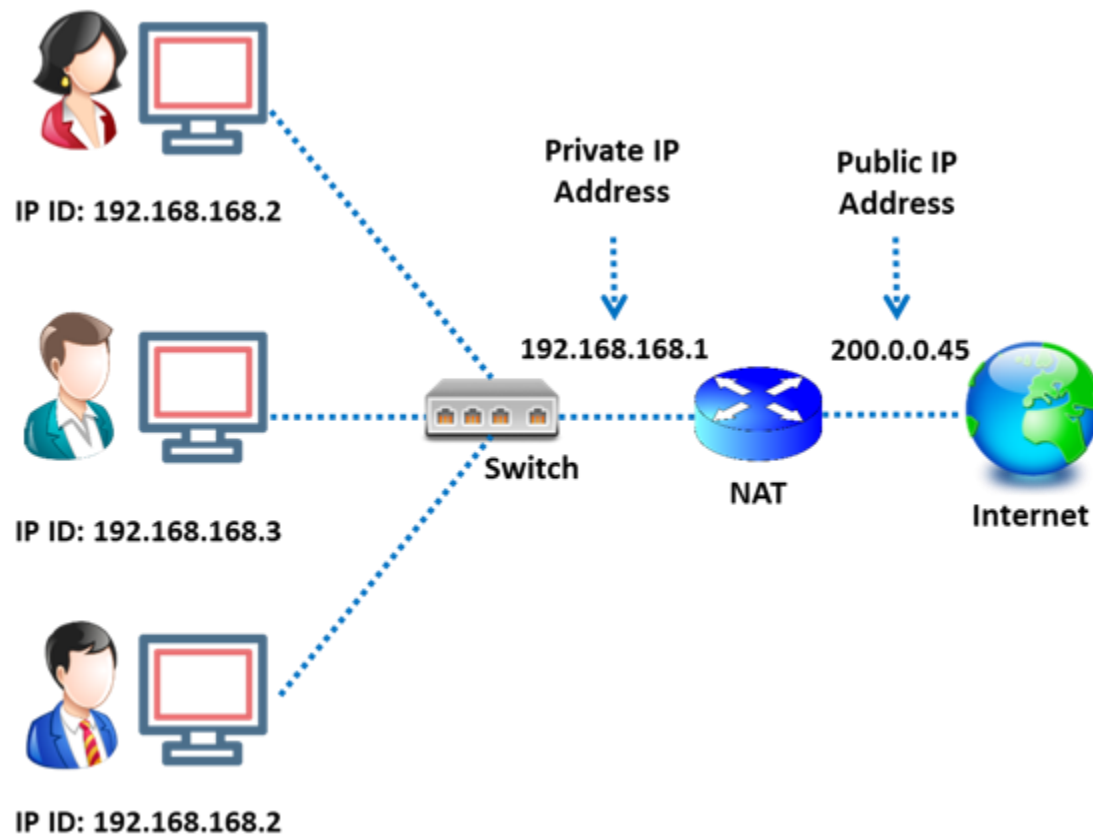


Figure 5.21: Illustration of network address translation

Advantages

- NAT help enforce the firewall's control over outbound connections.
- It restricts incoming traffic and allows only packets that are part of a current interaction initiated from the inside.
- It helps hide the internal network's configuration and thereby reduces vulnerability of the network or system from outside attacks.

Disadvantages

- The NAT system has to guess how long it should keep a particular translation, which is impossible to correctly guess every time.
- NAT interferes with encryption and authentication systems that ensure security of the data.
- Dynamic allocation of ports may interfere with packet filtering.

Next Generation Firewall (NGFW)

- ❑ Next generation firewall (NGFW) firewall technology is **third-generation firewall technology** that moves beyond port/protocol inspection
- ❑ In addition to traditional firewall capabilities, NGFW firewall technology has the capability to inspect traffic based on **packet content**
- ❑ Typical NGFW capabilities:
 - ✓ Deep packet inspection (DPI)
 - ✓ Encrypted traffic inspection
 - ✓ QoS/bandwidth management
 - ✓ Threat intelligence integration
 - ✓ Integrated intrusion prevention system
 - ✓ Advanced threat protection
 - ✓ Application control
 - ✓ Antivirus inspection

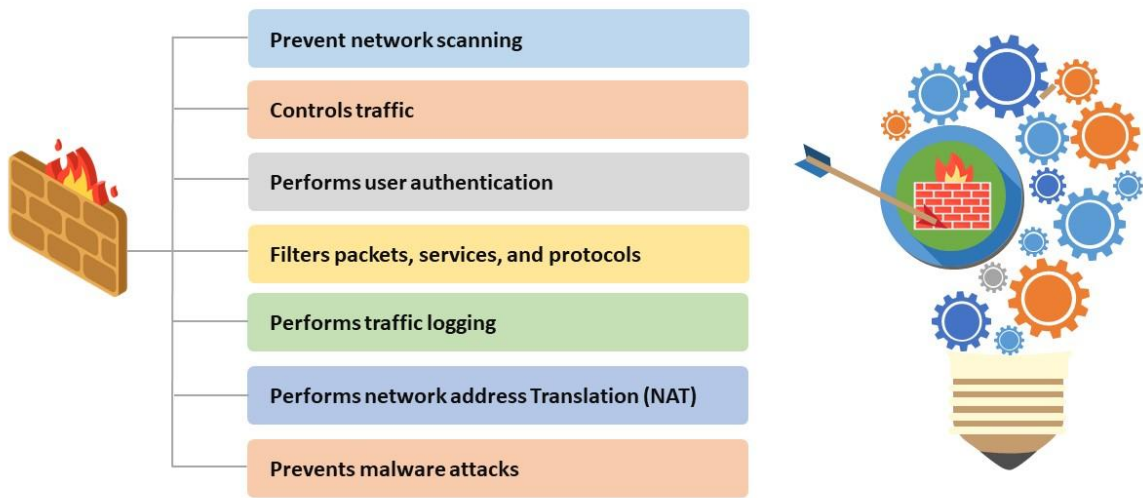


Copyright © by **EC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Next Generation Firewall (NGFW)

An NGFW is a third-generation network security device that provides firewalling, intrusion prevention, and application control. In addition to traditional firewall capabilities, NGFW firewall technology has the capability to inspect traffic based on packet content. It offers packet filtering and proxy-based decision making within layers 3 and 4. It also expands its protection at the application layer (layer 7).

Firewall Capabilities



Copyright © by **IC Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Firewall Capabilities

Be aware of a firewall's capabilities before planning for implementation. By knowing the capabilities of different types of firewalls, you will be able to decide what type to implement or whether a different security control or solution better suits your needs.

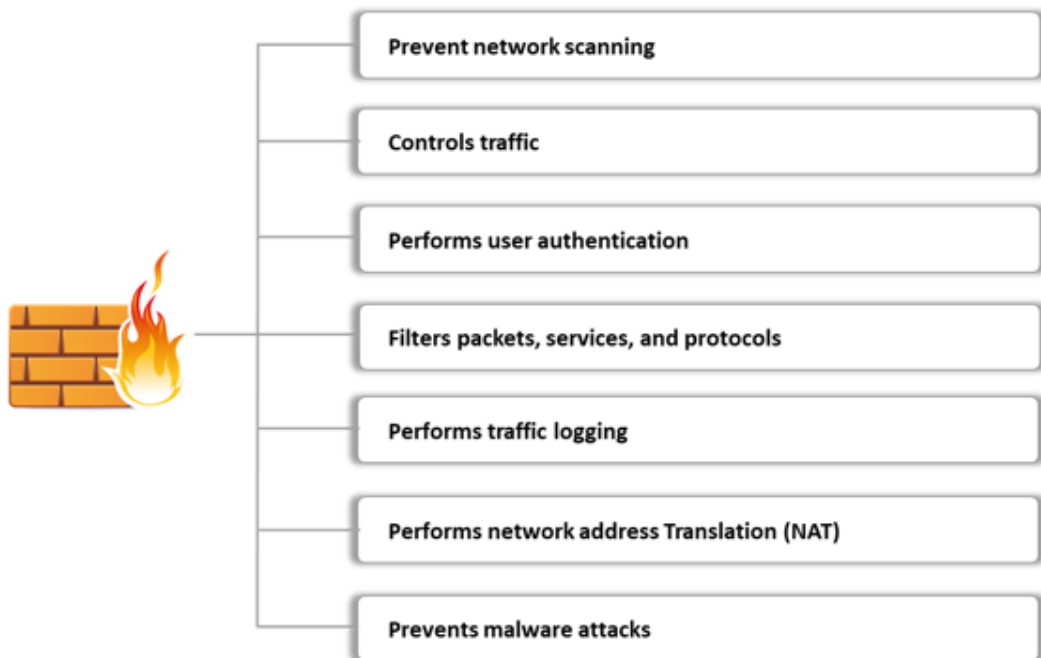


Figure 5.23: Firewall Capabilities

Firewall Limitations

1

A firewall does not prevent the network from **backdoor attacks**

2

A firewall does not protect the network from **insider attacks**

3

A firewall cannot do anything if the network design and **configuration is faulty**

4

A firewall is not an alternative to **antivirus** or **antimalware**

5

A firewall does not prevent **new viruses**

6

A firewall cannot prevent **social engineering threats**

7

A firewall does not prevent **passwords misuse**

8

A firewall does not block attacks from a higher level of the **protocol stack**

Intrusion Detection and Prevention System (IDS/IPS)

01

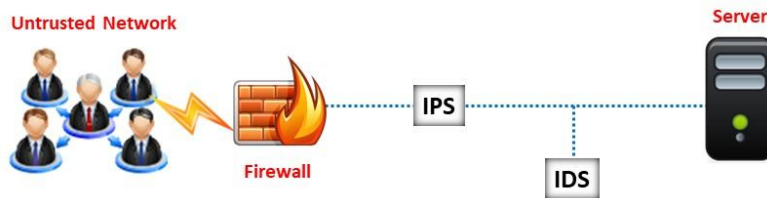
An intrusion detection and prevention system (IDS/IPS) is a network security appliance that **inspects all inbound and outbound network traffic** for suspicious patterns that might indicate a network or system security breach

02

If found, the IDS will alert the administrator about the **suspicious activities**

03

IDS checks the network traffic for **signatures** that match known intrusion patterns and triggers an alarm when a match is found



Copyright © by **IC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Intrusion Detection and Prevention System (IDS/IPS)

An Intrusion Detection and Prevention System (IPS/IDPS) is a network security appliance which inspects all inbound and outbound network traffic for suspicious patterns that could indicate a network or system security breach, identifies suspicious activity if any, logs information of the suspicious activity, reports it and attempts to block it. An intrusion prevention system (IPS) is an extension of the intrusion detection system (IDS). An IPS can

- Send alarms
- Defragment packet streams
- Drop identified malicious packets
- Reduce TCP sequencing issues
- Reset a connection
- Block traffic from a malicious IP address
- Correct cyclic redundancy check (CRC) errors
- Clean unneeded transport and network layer options

The Intrusion Detection System (IDS) monitors all inbound and outbound network activity and identifies malicious patterns by looking for known attack signatures and warns the security professionals of suspicious activity but does not prevent them. An IDS displays an alert, logs the event, or pages an administrator, reconfigures the network to mitigate the consequences of intrusions.

IDS vs. IPS

The key difference between an IPS and an IDS is that the IPS is implemented in-line, however the IDS sits off to the side. The traffic that is directed through an IPS either blocks or allows the packets depending on the policy and performs correction if needed. In the case of IDS, it is connected via a network tap and it monitors traffic, but cannot act directly.

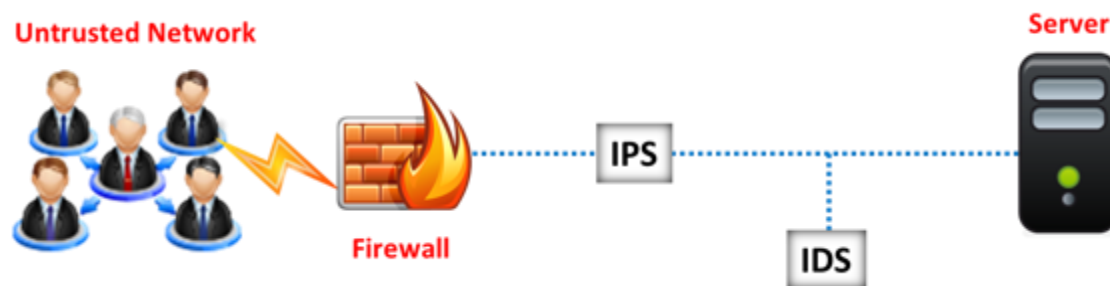
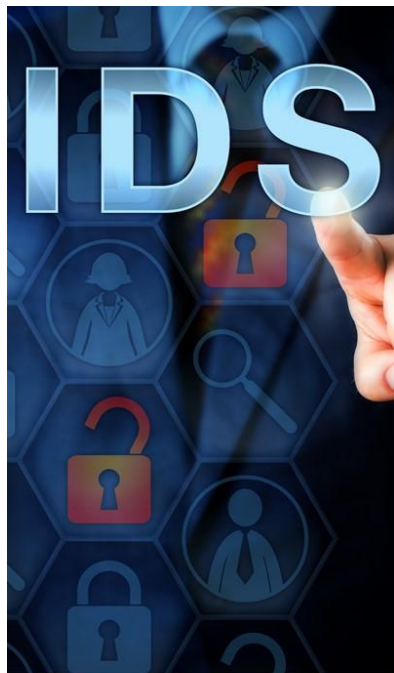
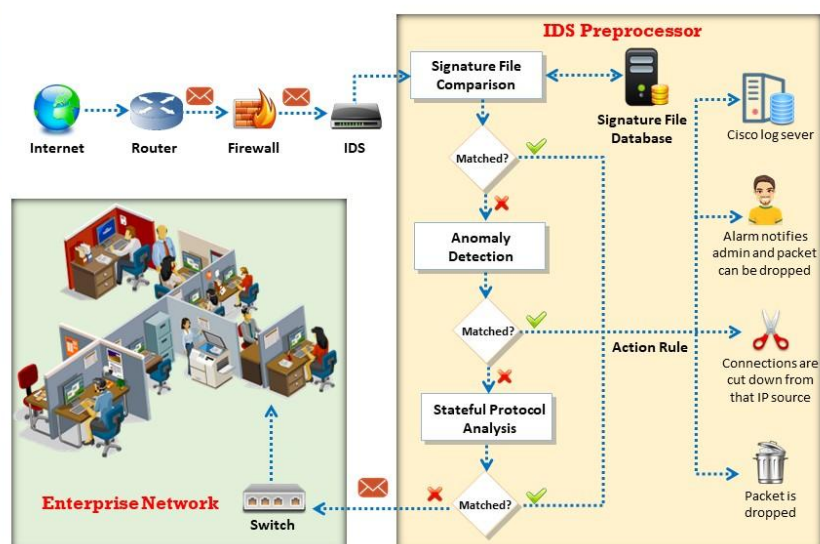


Figure 5.34: IDS vs. IPS



How does an IDS Work?



How does an IDS Work?

Signature-based IDS: In a signature-based IDS, the network traffic is checked with the databases that comprises of intrusions. As shown in the above figure, if an attack signature matches with any of the signatures in the signature file database, the connection will be disconnected down from the source IP, the packet will be dropped, the activity will be logged, and an alarm will be initiated. Alternatively, the packet will be moved to the next step called the anomaly detection step.

Anomaly-based IDS: An anomaly-based IDS uses statistical techniques to compare the monitored traffic with the normal traffic. This method can identify new forms of attacks that are not in the IDS signature database and issue a warning. The disadvantage of this method is issuing false positive messages, which will complicate the functioning of an administrator. In the anomaly detection step, if the attack signature matches, the connections will be disconnected from the source IP, the packet will be dropped, the activity will be logged, and an alarm will be initiated. Alternatively, the packet will be sent to stateful protocol analysis.

A stateful protocol analysis is used for detecting the deviations of the protocol state, which uses predetermined profiles based on the vendor-developed definitions of malicious activity. In the stateful protocol analysis, if the packet is matched, the connections will be disconnected from the source IP, the packets will be dropped, the activity will be logged, and an alarm will be initiated. Alternatively, the packet will be passed to the network through a switch.

An IDS performs an evaluation of a network traffic for illegal activities and policy violations. It performs a vulnerability assessment for ensuring the security of the network. The following are the features of IDS:

- Evaluating system and network activities
- Analyzing vulnerabilities in a network
- Measuring the system and file reliability
- Skill to identify the possibilities of attacks
- Monitoring irregular activities in a network and system
- Evaluating the policy violations

Organizations can identify the presence of attacks or intrusions from outside a network as well as the intrusions or misuse within that network. An IDS generally performs a vulnerability assessment or scanning in order to identify the vulnerabilities in a network and to monitor the security of the network.

Firewalls prevent intrusions within a network, but do not actually issue an alert regarding an intrusion or an attack. On the other hand, IDS systems can monitor and identify the intrusions within a network as well as signal an alarm to the administrator.

Role of an IDS in Network Defense



- ❑ An IDS works from inside the network, unlike a firewall which only looks **outside** the network for intrusions



- ❑ An IDS is placed behind the firewall, inspecting all the traffic, looking for **heuristics** and a **pattern** match for intrusions

Copyright © by **EC-Council**. All Rights Reserved. Reproduction is Strictly Prohibited.

Role of an IDS in Network Defense

Why Do We Need IDS?

Relying solely on a firewall for network security can provide a false sense of security. The firewall is simply implemented in the IT security policy to allow or deny traffic based on the policy rules. It allows certain packets to pass through or denies access if it does not meet certain criteria specified in a rule. It does not check the contents of legitimate traffic that are allowed based on the ruleset. Even legitimate traffic may contain malicious content, which is not evaluated during inspection by a firewall.

As an example, a firewall can be configured to pass traffic solely to port 80 of the Web server and to port 25 of the email server but it will not inspect the nature of the traffic flowing through either of these ports.

This is the reason why an IDS is implemented. An IDS will inspect the legitimate traffic coming from firewall and conduct signature-based analysis to identify malicious activity and raise an alarm to notify security professionals.

Role of an IDS in Network Defense

- An IDS works from inside the network, unlike a firewall which only looks outside the network for intrusions
- An IDS is placed behind the firewall, inspecting all the traffic, looking for heuristics and a pattern match for intrusions